POS governance gate review — 2026-09-24

Outcome

The governance scripts now reject demonstrated false-pass paths. The business gates remain honestly blocked: G1 has **13/13 structural checks, 0/11 approved decisions**; the program has **12/12 structural checks, 0/10 passed gates, 0/9 verified external items**. Production authorization remains false. The extra program check requires an actual bound closure attestation before any non-G1 declared pass is accepted.

No contract, approval-register or program business JSON was edited. No trust key, approval, provider result, fiscal opinion, device certification, database mutation or production action was created. Existing completed migration and browser results were not repeated or reclassified.

Fresh baseline and findings

Baseline commands were run against the current working tree, saving G1 before and program before. They reproduced 13/13 + 0/11 and 11/11 + 0/10 + 0/9 respectively, with expected fail-mode exit 1.

Finding	Before	Remediation / disposition
GOV-01: fabricated signature evidence	An invented approver/reference and 64-character digest were accepted without reading or authenticating evidence	A local envelope must hash-match, verify under an independently configured Ed25519 issuer key, bind exact contract/decision/scope/identity and include intact supporting artifacts. Missing trust configuration blocks credit.
GOV-02: approval temporal/version drift	Future approvals, expired decision review dates, and unrelated effective versions could pass field-presence checks	Enforce UTC timestamps, approval after fresh authentication within ten minutes, no future approval, unexpired decision/attestation/key, and exact contract version.
GOV-03: mutable dependency bypass	Removing a gate's dependencies was accepted as a valid acyclic graph	Compare the full canonical dependency graph; reject missing/duplicate gates and dependency edits.
GOV-04: external register bypass	An empty external register passed vacuous `every` checks; a fabricated verification reference counted as verified	Require exact nine-item ID/owner mapping; count only authenticated class-scoped evidence. Local test classes cannot substitute for external classes.
GOV-05: declared-pass fallthrough	A gate marked PASSED remained PASSED when its external evidence was missing because the fallback returned its declared status	Dependencies, validated closure evidence and validated external evidence independently control derived status; otherwise block.
GOV-06: status-only internal closure	Required evidence and stop-condition arrays were checked only for existence; manually editing status supplied closure	A signed closure binds candidate, contract, dependency/requirement/stop-condition scope, supporting artifacts and a currently matching source manifest. Unbound declared passes invalidate the control plane.

Finding	Before	Remediation / disposition
GOV-07: stale candidate	Program records HEAD `35b4cc6a06a50ee11de5bfce6b04993e38bd589a` ; checkout is `a05a41ef66cd5d98fd69ae3df18225795f912232`	Report the mismatch and refuse external/closure evidence for that stale candidate. The program candidate was not silently rewritten.
GOV-08: structural checks overinterpreted	Source-string markers and historical G0 status can be mistaken for fresh behavioral proof	Reports explicitly classify source checks as structural preflight and G0 as historical baseline only. Actual gate closure requires scoped reviewed evidence. Runtime tests remain independently required.

Five negative regressions were executed against the original Git HEAD gate scripts using an isolated evidence-only harness: **5 failed as expected, 4 prior checks passed**, demonstrating approval reference/future-time, missing register, dependency removal and invented external verification weaknesses. See original failures. The current workspace scripts were not restored or overwritten to create that harness.

Verification

Command / evidence	Result
`node node_modules/jest/bin/jest.js --config what-next/pos-release-gate-closure/2026-09-24-run-01/evidence/governance-before-harness/jest.config.json --runInBand`	Original scripts: exit 1; 5 expected failures, 4 passes
`node node_modules/jest/bin/jest.js --config what-next/pos-release-gate-closure/2026-09-24-run-01/evidence/governance-jest.config.json --runInBand`	Hardened scripts: exit 0; **3 suites, 45 tests passed**; log
Scoped `eslint` on the three gate/verifier files and four test/fixture files	Exit 0, no diagnostics; log
`node --check` on G1, program, and verifier scripts	Exit 0
`git diff --check` on changed tracked gate/tests	Exit 0
G1 fail-mode report with explicit new `--out` / `--json-out` paths	Exit 1, expected genuine approval blockers; after report
Program fail-mode report with explicit new `--out` / `--json-out` paths	Exit 1, expected G1/dependency/evidence blockers; after report

The initial default Jest invocation was interrupted after producing no test output while resolving the large repository. It is not counted as a pass. A focused Node-only Jest config was used for these pure JavaScript scripts, with no Next.js transformation, browser, database, global setup or broad repository crawl.

Positive coverage includes real ephemeral Ed25519 signatures, intact artifact binding, a valid role-complete decision, and program composition after upstream/closure proofs. Negative coverage includes forged signatures, replaced digest/bytes, changed contract hash/scope/decision/identity, missing role, stale authentication, expiry/future/invalid dates, unauthorized evidence classes, revoked trust keys, altered source artifacts, path escapes/remote references, candidate-provided trust stores, removed/duplicate gate/register entries, missing internal closure, external evidence missing despite a declared pass, and distinct Cameroon reviewer/checker or explicit hardware exclusion scope. Program composition tests mock already-verified proofs solely to isolate dependency logic; signature tests use actual cryptography in temporary synthetic fixtures.

Approval/evidence supply and remaining boundaries

Approval verifier contract specifies the exact register/envelope format and exported binding helpers for the owner packets. It is a supplementary machine-verification proposal supported by tests, not an organizational approval system or proof that a real reviewer exists.

Security/IAM and CI operators must select an authentic issuer, verify its review/authentication process, and provision its public key independently outside the workspace. Missing trust configuration is currently explicit as `TRUST_ANCHORS_NOT_CONFIGURED`. The issuer must attest real identity/role/authority, expert qualification, provider/hardware/drill/pilot facts and source-manifest completeness; the local tool authenticates that attestation and verifies bytes/scope/time, not the underlying real-world facts itself. No arbitrary remote references are fetched.

The source manifest is an explicit reviewed list, not automatic proof that every relevant file was included. The accountable issuer must review completeness and the appropriate immutable candidate boundary. Historical source markers and work-package strings are never sufficient evidence. The old dirty development candidate and its production freeze requirement remain visible. The trusted-key file and CI environment require independent operator access control; candidate code review and CI integrity remain part of the release boundary.

Actual D-01–D-11 approvals, provider sandbox results, qualified fiscal review, physical hardware or explicit exclusions, close-cycle evidence, inventory/receivables policy approvals, operational drills and pilot decisions remain external requirements. Local test success must not be entered as any of those facts. Independent blockers are now listed even where an upstream gate also prevents advancement.

Review responsibilities

Platform/backend/security/IAM: gate trust boundaries, exact decision/scope binding, dependency integrity and path-safe local evidence were reviewed. QA/release/data governance: historical-vs-current evidence, candidate drift, expected failure reproduction, positive/negative acceptance and report non-claims were reviewed. Product/finance/inventory/payments/fiscal/hardware/operations: required roles, classes and gate scopes were retained and their evidence remains unapproved. Browser/accessibility/localization/UI and financial runtime implementation changes are not applicable to this bounded tooling patch; root-owned review covers those surfaces separately. No commercial packaging or AI behavior changed.